

Security Export

SCA scan: DONE, Mon Nov 17, 2025

Contextual Analysis scan: DONE, Tue Sep 16, 2025

Exported on: Mon Nov 17, 2025

Exported by: dudi

Package type: Docker

Sha256: 021199a4ff64806286ec3bd5c65079668256f18ee915483f9bc05ea0c92b0e0d

Component name: ubuntu-jammy:latest



Summary	CVEs	Severity	JFrog Severity	Component Physical Paths	Component	Infected Version	Fix Version	Edited	Applicability
A flaw was found in linux-pam. The pam_namespace module may improperly handle user-controlled paths, allowing local users to exploit symlink attacks and race conditions to elevate their privileges to root. This CVE provides a "complete" fix for CVE-2025-6020.	CVE-2025-8941	Medium		sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/libpam-runtime:1.4.0-11ubuntu2.6; sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/libpam0g:1.4.0-11ubuntu2.6; sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/libpam-modules:1.4.0-11ubuntu2.6; sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/libpam-modules-bin:1.4.0-11ubuntu2.6	ubuntu:libpam-modules-bin	All Versions		0001-01-01T00:00:00Z	Not Applicable
A vulnerability was found in zstd v1.4.10, where an attacker can supply empty string as an argument to the command line tool to cause buffer overrun.	CVE-2022-4899	Low	Low	sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/libzstd1:1.4.8+dfsg-3build1	ubuntu:libzstd1	All Versions		2023-05-14T11:37:00Z	Not Applicable

Summary	CVEs	Severity	JFrog Severity	Component Physical Paths	Component	Infected Version	Fix Version	Edited	Applicability
Integer overflow vulnerability in pcre2test before 10.41 allows attackers to cause a denial of service or other unspecified impacts via negative input.	CVE-2022-41409	Low		sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/libpcre2-8-0:10.39-3ubuntu0.1	ubuntu:libpcre2-8-0	All Versions		0001-01-01T00:00:00Z	Not Applicable
Issue summary: An application trying to decrypt CMS messages encrypted using password based encryption can trigger an out-of-bounds read and write. Impact summary: This out-of-bounds read may trigger a crash which leads to Denial of Service for an application. The out-of-bounds write can cause a memory corruption which can have various consequences including a Denial of Service or Execution of attacker-supplied code. Although the consequences of a successful exploit of this vulnerability could be severe, the probability that the attacker would be able to perform it is low. Besides, password based (PWRI) encryption support in CMS messages is very rarely used. For that reason the issue was assessed as Moderate severity according to our Security Policy. The FIPS modules in 3.5, 3.4, 3.3, 3.2, 3.1 and 3.0 are not affected by this issue, as the CMS implementation is outside the OpenSSL FIPS module boundary.	CVE-2025-9230	Medium	Medium	sha256__8ca6a62d6bde555e8cd645d52929b474f617bd8d1d5780bfe9b75c9b5c29f5f2.tar.gz/openssl:3.0.2-0ubuntu1.19	ubuntu:openssl	< 3.0.2-0ubuntu1.20	3.0.2-0ubuntu1.20	0001-01-01T00:00:00Z	Rescan Required

Summary	CVEs	Severity	JFrog Severity	Component Physical Paths	Component	Infected Version	Fix Version	Edited	Applicability
The regcomp function in the GNU C library version from 2.4 to 2.41 is subject to a double free if some previous allocation fails. It can be accomplished either by a malloc failure or by using an interposed malloc that injects random malloc failures. The double free can allow buffer manipulation depending of how the regex is constructed. This issue affects all architectures and ABIs supported by the GNU C library.	CVE-2025-8058	Medium		sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/libc6:2.35-0ubuntu3.10; sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/libc-bin:2.35-0ubuntu3.10	ubuntu:libc-bin	< 2.35-0ubuntu3.11	2.35-0ubuntu3.11	0001-01-01T00:00:00Z	Not Covered

Summary	CVEs	Severity	JFrog Severity	Component Physical Paths	Component	Infected Version	Fix Version	Edited	Applicability
GNU Tar through 1.35 allows file overwrite via directory traversal in crafted TAR archives, with a certain two-step process. First, the victim must extract an archive that contains a ../ symlink to a critical directory. Second, the victim must extract an archive that contains a critical file, specified via a relative pathname that begins with the symlink name and ends with that critical file's name. Here, the extraction follows the symlink and overwrites the critical file. This bypasses the protection mechanism of "Member name contains '..'" that would occur for a single TAR archive that attempted to specify the critical file via a ../ approach. For example, the first archive can contain "x -> .././././././home/victim/.ssh" and the second archive can contain x/authorized_keys. This can affect server applications that automatically extract any number of user-supplied TAR archives, and were relying on the blocking of traversal. This can also affect software installation processes in which "tar xf" is run more than once (e.g., when installing a package can automatically install two dependencies that are set up as untrusted tarballs instead of official packages). NOTE: the official GNU Tar manual has an otherwise-empty directory for each "tar xf" in its Security Rules of Thumb; however, third-party advice leads users to run "tar xf" more than once into the same directory.	CVE-2025-45582	Medium		sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/tar:1.34+dfsg-1ubuntu0.1.22.04.2	ubuntu:tar	All Versions		0001-01-01T00:00:00Z	Not Covered

Summary	CVEs	Severity	JFrog Severity	Component Physical Paths	Component	Infected Version	Fix Version	Edited	Applicability
1. A cookie is set using the `secure` keyword for `https://target` 2. curl is redirected to or otherwise made to speak with `http://target` (same hostname, but using clear text HTTP) using the same cookie set 3. The same cookie name is set - but with just a slash as path (`path=/`). Since this site is not secure, the cookie *should* just be ignored. 4. A bug in the path comparison logic makes curl read outside a heap buffer boundary The bug either causes a crash or it potentially makes the comparison come to the wrong conclusion and lets the clear-text site override the contents of the secure cookie, contrary to expectations and depending on the memory contents immediately following the single-byte allocation that holds the path. The presumed and correct behavior would be to plainly ignore the second set of the cookie since it was already set as secure on a secure host so overriding it on an insecure host should not be okay.	CVE-2025-9086	Low	Low	sha256__8ca6a62d6bde555e8cd645d52929b474f617bd8d1d5780bfe9b75c9b5c29f5f2.tar.gz/curl:7.81.0-1ubuntu1.20; sha256__8ca6a62d6bde555e8cd645d52929b474f617bd8d1d5780bfe9b75c9b5c29f5f2.tar.gz/libcurl4:7.81.0-1ubuntu1.20	ubuntu:curl	All Versions		0001-01-01T00:00:00Z	Rescan Required
In PCRE 8.41, the OP_KETRMATCH feature in the match function in pcre_exec.c allows stack exhaustion (uncontrolled recursion) when processing a crafted regular expression.	CVE-2017-11164	Low		sha256__8bbf5fac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/libpcre3:2:8.39-13ubuntu0.22.04.1	ubuntu:libpcre3	All Versions		0001-01-01T00:00:00Z	Undetermined

Summary	CVEs	Severity	JFrog Severity	Component Physical Paths	Component	Infected Version	Fix Version	Edited	Applicability
It was discovered that dpkg-deb does not properly sanitize directory permissions when extracting a control member into a temporary directory, which is documented as being a safe operation even on untrusted data. This may result in leaving temporary files behind on cleanup. Given automated and repeated execution of dpkg-deb commands on adversarial .deb packages or with well compressible files, placed inside a directory with permissions not allowing removal by a non-root user, this can end up in a DoS scenario due to causing disk quota exhaustion or disk full conditions.	CVE-2025-6297	Low		sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/dpkg:1.21.1ubuntu2.3	ubuntu:dpkg	< 1.21.1ubuntu2.6	1.21.1ubuntu2.6	0001-01-01T00:00:00Z	Rescan Required
When asked to use a `netrc` file for credentials **and** to follow HTTP redirects, curl could leak the password used for the first host to the followed-to host under certain circumstances. This flaw only manifests itself if the netrc file has a `default` entry that omits both login and password. A rare circumstance.	CVE-2025-0167	Low		sha256__8ca6a62d6bde555e8cd645d52929b474f617bd8d1d5780bfe9b75c9b5c29f5f2.tar.gz/libcurl4:7.81.0-1ubuntu1.20; sha256__8ca6a62d6bde555e8cd645d52929b474f617bd8d1d5780bfe9b75c9b5c29f5f2.tar.gz/curl:7.81.0-1ubuntu1.20	ubuntu:curl	All Versions		0001-01-01T00:00:00Z	Not Covered

Summary	CVEs	Severity	JFrog Severity	Component Physical Paths	Component	Infected Version	Fix Version	Edited	Applicability
shadow-utils (aka shadow) 4.4 through 4.17.0 establishes a default /etc/subuid behavior (e.g., uid 100000 through 165535 for the first user account) that can realistically conflict with the uids of users defined on locally administered networks, potentially leading to account takeover, e.g., by leveraging newuidmap for access to an NFS home directory (or same-host resources in the case of remote logins by these local network users). NOTE: it may also be argued that system administrators should not have assigned uids, within local networks, that are within the range that can occur in /etc/subuid.	CVE-2024-56433	Low		sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/passwd:1:4.8.1-2ubuntu2.2; sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/login:1:4.8.1-2ubuntu2.2	ubuntu:login	All Versions		0001-01-01T00:00:00Z	Not Covered
Validating the order of the public keys in the Diffie-Hellman Key Agreement Protocol, when an approved safe prime is used, allows remote attackers (from the client side) to trigger unnecessarily expensive server-side DHE modular-exponentiation calculations. The client may cause asymmetric resource consumption. The basic attack scenario is that the client must claim that it can only communicate with DHE, and the server must be configured to allow DHE and validate the order of the public key.	CVE-2024-41996	Low		sha256__8ca6a62d6bde555e8cd645d52929b474f617bd8d1d5780bfe9b75c9b5c29f5f2.tar.gz/openssl:3.0.2-0ubuntu1.19; sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/libssl3:3.0.2-0ubuntu1.19	ubuntu:libssl3	All Versions		0001-01-01T00:00:00Z	Not Covered
A timing-based side-channel flaw was found in libgrypt's RSA implementation. This issue may allow a remote attacker to initiate a Bleichenbacher-style attack, which can lead to the decryption of RSA ciphertexts.	CVE-2024-2236	Low		sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/libgrypt20:1.9.4-3ubuntu3	ubuntu:libgrypt20	All Versions		0001-01-01T00:00:00Z	Not Covered

Summary	CVEs	Severity	JFrog Severity	Component Physical Paths	Component	Infected Version	Fix Version	Edited	Applicability
A vulnerability was found in systemd-resolved. This issue may allow systemd-resolved to accept records of DNSSEC-signed domains even when they have no signature, allowing man-in-the-middles (or the upstream DNS resolver) to manipulate records.	CVE-2023-7008	Low		sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/libudev1:249.11-0ubuntu3.16; sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/libsystemd0:249.11-0ubuntu3.16	ubuntu:libsystemd0	All Versions		0001-01-01T00:00:00Z	Not Covered
Ncurses v6.4-20230418 was discovered to contain a segmentation fault via the component _nc_wrap_entry().	CVE-2023-50495	Low		sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/libncurses6:6.3-2ubuntu0.1; sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/libtinfo6:6.3-2ubuntu0.1; sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/libncursesw6:6.3-2ubuntu0.1; sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/ncurses-bin:6.3-2ubuntu0.1; sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/ncurses-base:6.3-2ubuntu0.1	ubuntu:libncurses6	All Versions		0001-01-01T00:00:00Z	Not Covered

Summary	CVEs	Severity	JFrog Severity	Component Physical Paths	Component	Infected Version	Fix Version	Edited	Applicability
In Shadow 4.13, it is possible to inject control characters into fields provided to the SUID program chfn (change finger). Although it is not possible to exploit this directly (e.g., adding a new user fails because \n is in the block list), it is possible to misrepresent the /etc/passwd file when viewed. Use of \r manipulations and Unicode characters to work around blocking of the : character make it possible to give the impression that a new user has been added. In other words, an adversary may be able to convince a system administrator to take the system offline (an indirect, social-engineered denial of service) by demonstrating that "cat /etc/passwd" shows a rogue user account.	CVE-2023-29383	Low		sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/passwd:1:4.8.1-2ubuntu2.2; sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/login:1:4.8.1-2ubuntu2.2	ubuntu:login	All Versions		0001-01-01T00:00:00Z	Not Covered
libiberty/rust-demangle.c in GNU GCC 11.2 allows stack consumption in demangle_const, as demonstrated by nm-new.	CVE-2022-27943	Low		sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/libgcc-s1:12.3.0-1ubuntu1~22.04.2; sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/gcc-12-base:12.3.0-1ubuntu1~22.04.2; sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/libstdc++6:12.3.0-1ubuntu1~22.04.2	ubuntu:gcc-12-base	All Versions		0001-01-01T00:00:00Z	Not Covered
chroot in GNU coreutils, when used with --userspec, allows local users to escape to the parent session via a crafted TIOCSTI ioctl call, which pushes characters to the terminal's input buffer.	CVE-2016-2781	Low		sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/coreutils:8.32-4.1ubuntu1.2	ubuntu:coreutils	All Versions		0001-01-01T00:00:00Z	Not Covered
GnuPG can be made to spin on a relatively small input by (for example) crafting a public key with thousands of signatures attached, compressed down to just a few KB.	CVE-2022-3219	Low		sha256__8bbfefac75f44cec45a58cc5e5ea42260017a8f2e72fa4fa9663869eb9550bc5.tar.gz/gpgv:2.2.27-3ubuntu2.4	ubuntu:gpgv	All Versions		0001-01-01T00:00:00Z	Not Covered